GUÍA DE ESTUDIO

Introducción a la Arquitectura de Seguridad: CIA Triad, Zero Trust y Principios de Diseño

UNIDAD	SEMANA	TIPO	NIVEL
U1	Sem 1	ESTUDIO	Avanzado

CUGDL — Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Marzo 2026

OBJETIVOS DE APRENDIZAJE

1. Explicar qué es la arquitectura de seguridad y por qué es una disciplina distinta a la implementación de controles técnicos aislados.
2. Describir los tres pilares del CIA Triad y aplicarlos a escenarios reales para identificar qué pilar está siendo afectado en un incidente.
3. Distinguir el modelo de seguridad perimetral del modelo Zero Trust y argumentar cuándo cada uno es apropiado.
4. Aplicar los tres principios de diseño —defensa en profundidad, mínimo privilegio y segmentación— al análisis de una arquitectura existente.

1. ¿Qué es la Arquitectura de Seguridad?

La arquitectura de seguridad es el conjunto de decisiones de diseño que determinan cómo se protege un sistema de información. No es una lista de herramientas ni un conjunto de configuraciones — es un marco de pensamiento que responde tres preguntas fundamentales: ¿qué proteger?, ¿de qué amenazas?, y ¿cómo estructurar las defensas para que sean efectivas y sostenibles?

La diferencia entre implementar controles de seguridad y diseñar una arquitectura de seguridad es la misma que hay entre escribir código que funciona y diseñar un sistema escalable. Un desarrollador puede escribir una función que resuelve un problema — un arquitecto diseña el sistema completo considerando cómo esa función interactúa con el resto, cómo falla, y cómo evoluciona con el tiempo.

	ANALOGÍA - Data Engineering
	Implementar controles de seguridad sin arquitectura es como crear pipelines de datos sin diseño: cada pipeline funciona solo, pero el sistema completo es frágil, inconsistente y difícil de mantener.
	La arquitectura de seguridad es el diseño del Data Platform: define las capas, los flujos, las políticas de acceso y los puntos de fallo — antes de escribir una sola línea de código.

2. CIA Triad — Los Tres Pilares de la Seguridad

El CIA Triad es el modelo fundamental de la seguridad de la información. Define los tres atributos que toda arquitectura de seguridad debe proteger: Confidencialidad, Integridad y Disponibilidad. Cada incidente de seguridad afecta al menos uno de estos tres pilares — y el análisis de cuál fue afectado determina qué controles fallaron y cuáles se necesitan.

2.1 Confidencialidad

La confidencialidad garantiza que la información solo sea accesible para quienes están autorizados a verla. Se viola cuando información sensible es expuesta a personas no autorizadas — ya sea por un ataque externo, un error interno o una configuración incorrecta.

Controles que protegen la Confidencialidad

- Cifrado en reposo y en tránsito — los datos son ilegibles sin la clave.
- Control de acceso basado en roles (RBAC) — cada usuario accede solo a lo que necesita.
- Autenticación multifactor (MFA) — impide acceso con solo credenciales robadas.
- Clasificación de datos — saber qué datos son sensibles para protegerlos adecuadamente.

2.2 Integridad

La integridad garantiza que la información no ha sido modificada de forma no autorizada. Se viola cuando datos son alterados, corrompidos o falsificados — ya sea intencionalmente por un atacante o accidentalmente por un fallo del sistema.

Controles que protegen la Integridad

- Hashing (SHA-256, MD5) — genera una huella digital del dato para detectar modificaciones.
- Firmas digitales — verifican que un documento no fue alterado y autentica al firmante.
- Logs de auditoría inmutables — registro de cambios que no puede ser modificado.
- Control de versiones — permite detectar y revertir cambios no autorizados.

2.3 Disponibilidad

La disponibilidad garantiza que los sistemas y datos estén accesibles cuando los usuarios autorizados los necesitan. Se viola cuando un servicio cae — ya sea por un ataque de denegación de servicio (DoS), un fallo de hardware, un error de configuración o un desastre natural.

Controles que protegen la Disponibilidad

- Alta disponibilidad (HA) — servidores redundantes que toman el relevo si uno falla.
- Backups y recuperación ante desastres (DRP) — restaurar datos y servicios tras un incidente.
- Balanceadores de carga — distribuyen el tráfico para evitar que un solo servidor se sature.
- Protección contra DDoS — filtra tráfico malicioso antes de que llegue al servidor.

Pilar	Pregunta clave	Amenaza típica	Control principal
Confidencialidad	¿Solo los autorizados pueden ver esto?	Fuga de datos, espionaje	Cifrado + control de acceso
Integridad	¿Los datos son exactos y no fueron alterados?	Ransomware, manipulación	Hashing + firmas digitales
Disponibilidad	¿El servicio está accesible cuando se necesita?	DDoS, fallo de hardware	Redundancia + backups

3. Modelos de Seguridad: Perímetro vs. Zero Trust

Durante décadas, la seguridad se diseñó alrededor de un perímetro: una frontera clara entre lo que está adentro (confiable) y lo que está afuera (no confiable). El firewall era el muro, y todo lo que estaba dentro de ese muro se consideraba seguro. Este modelo funcionó bien cuando las aplicaciones vivían en servidores físicos dentro de un edificio y los empleados trabajaban desde oficinas fijas.

El problema es que ese mundo ya no existe. Las aplicaciones están en la nube, los empleados trabajan desde casa, los proveedores acceden remotamente, y los atacantes ya saben cómo cruzar el perímetro. El modelo perimetral asume que todo lo que está adentro es confiable — y esa suposición es exactamente lo que los atacantes explotan.

3.1 Modelo Perimetral — Castle and Moat

El modelo perimetral funciona como un castillo medieval: un foso (firewall) rodea el castillo (red interna). Todo lo que está dentro del foso es confiable, todo lo que está fuera es enemigo. Una vez que un atacante cruza el foso — por phishing, credenciales robadas o una VPN comprometida — tiene acceso libre a todo el interior.

- Ventaja: simple de implementar y administrar.
- Ventaja: efectivo cuando todos los recursos están dentro del perímetro.
- Desventaja: una brecha en el perímetro compromete todo.
- Desventaja: no funciona con cloud, trabajo remoto ni proveedores externos.
- Desventaja: no detecta amenazas internas — un empleado malicioso ya está adentro.

3.2 Zero Trust — Never Trust, Always Verify

Zero Trust es un modelo de seguridad que elimina el concepto de confianza implícita. No importa si estás dentro de la red corporativa o fuera — cada solicitud de acceso debe ser autenticada, autorizada y verificada continuamente. El principio fundamental es: nunca confíes, siempre verifica.

Zero Trust no es un producto ni una tecnología — es una filosofía de diseño. Se implementa combinando múltiples controles: identidad fuerte, acceso mínimo privilegio, microsegmentación y monitoreo continuo.

Criterio	Modelo Perimetral	Zero Trust
Suposición base	Lo que está adentro es confiable	Nada es confiable por defecto
Verificación	Una vez al entrar a la red	Continua en cada solicitud
Acceso	Amplio una vez dentro	Mínimo privilegio siempre
Amenaza interna	No la contempla	La asume como posible
Cloud y remoto	Difícil de aplicar	Diseñado para este contexto
Complejidad	Baja	Alta — requiere más infraestructura
Caso de uso ideal	Red local tradicional	Entornos híbridos y cloud

💡	**ANALOGÍA — Acceso a un Data Lake**
	Modelo perimetral: una vez que tienes acceso a la VPN, puedes leer cualquier tabla del Data Lake.
	Zero Trust: aunque tengas acceso a la VPN, cada consulta al Data Lake verifica tu identidad, tu rol y si esa consulta específica está autorizada para ti en este momento.

Los 5 pilares de Zero Trust (NIST SP 800-207)

- Identidad — verificar quién es el usuario con MFA y autenticación continua.
- Dispositivo — verificar que el dispositivo que accede cumple las políticas de seguridad.
- Red — microsegmentar la red para limitar el movimiento lateral.
- Aplicación — controlar el acceso a nivel de aplicación, no solo de red.
- Datos — cifrar y clasificar los datos, controlar quién puede acceder a qué.

4. Principios de Diseño de Arquitecturas Seguras

Los principios de diseño son las reglas que guían las decisiones de arquitectura. No son tecnologías específicas — son criterios de evaluación que aplican independientemente de la plataforma, el proveedor o el contexto. Una arquitectura que viola estos principios es frágil por diseño, sin importar qué tan avanzadas sean las herramientas que use.

4.1 Defensa en Profundidad

Ningún control de seguridad es perfecto. La defensa en profundidad establece que la seguridad efectiva requiere múltiples capas independientes — si una capa falla, las siguientes contienen el daño. La pregunta clave de diseño es: si este control falla completamente, ¿qué capa siguiente lo detecta o contiene?

- Capa 1 — Perímetro: firewall NGFW, DMZ.
- Capa 2 — Red: VLANs, segmentación.
- Capa 3 — Detección: IDS/IPS, SIEM.
- Capa 4 — Endpoint: antivirus, EDR.
- Capa 5 — Aplicación: WAF, autenticación MFA.
- Capa 6 — Datos: cifrado, control de acceso granular.

4.2 Mínimo Privilegio

Cada usuario, proceso o sistema debe tener acceso únicamente a los recursos que necesita para cumplir su función — nada más. Este principio limita el daño que puede causar una cuenta comprometida o un empleado malicioso.

- Un desarrollador no necesita acceso a producción.
- Un servidor web no necesita acceso a la base de datos de recursos humanos.
- Un proveedor externo no necesita acceso a la red interna completa — solo al sistema específico que administra.
- Una cuenta de servicio no necesita permisos de administrador.

4.3 Segmentación

La segmentación divide un sistema en zonas con diferentes niveles de confianza y controla el tráfico entre ellas. Su objetivo es contener el daño — si un segmento es comprometido, el atacante no puede moverse libremente al resto del sistema.

- Segmentación de red: VLANs, DMZ, subredes por función.
- Segmentación de aplicación: microservicios con políticas de comunicación entre ellos.
- Segmentación de datos: clasificación y control de acceso por nivel de sensibilidad.

Principio	Pregunta que responde	Si se viola...
Defensa en profundidad	¿Si esta capa falla, qué la contiene?	Una sola brecha compromete todo el sistema
Mínimo privilegio	¿Tiene acceso solo a lo que necesita?	Una cuenta comprometida tiene acceso excesivo
Segmentación	¿Está dividido en zonas controladas?	Un atacante dentro puede moverse libremente

CASO REAL: Uber - Brecha por falta de Zero Trust (2022)

En 2022, un atacante de 18 años comprometió la red interna de Uber mediante ingeniería social — convenció a un empleado de aprobar una solicitud de MFA falsa (MFA fatigue attack). Una vez dentro, encontró credenciales de administrador en un script de PowerShell almacenado en una carpeta de red compartida. Con esas credenciales accedió a prácticamente todos los sistemas internos de Uber.

Conexión con esta guía: el ataque violó los tres principios simultáneamente. Sin defensa en profundidad: cruzar el MFA fue suficiente para acceder a todo. Sin mínimo privilegio: las credenciales de administrador estaban en un archivo accesible para cualquier empleado. Sin segmentación: una vez dentro, no había zonas que contuvieran el movimiento lateral. Un modelo Zero Trust con acceso granular por recurso habría limitado drásticamente el alcance del daño.

PREGUNTAS DE REFLEXIÓN

1. Un hospital implementa un sistema de expedientes médicos electrónicos en la nube. Los médicos acceden desde sus teléfonos personales y desde computadoras del hospital. ¿Qué pilar del CIA Triad es más crítico proteger y por qué? ¿Qué modelo de seguridad —perimetral o Zero Trust— recomendarías?

2. El principio de mínimo privilegio reduce la superficie de ataque pero aumenta la complejidad operativa — más roles, más políticas, más administración. ¿Cómo balancearías seguridad vs. usabilidad en una empresa de 50 personas sin equipo de IT dedicado?
3. Zero Trust asume que la red interna no es confiable. ¿Qué implicaciones tiene esto para el diseño de aplicaciones internas? ¿Cómo cambiaría el desarrollo de un sistema que antes asumía que todos los usuarios de la red eran de confianza?

RECURSOS

- [Docs] NIST SP 800-207 — Zero Trust Architecture — https://csrc.nist.gov/publications/detail/sp/800-207/final — gratuito
- [Docs] CISA Zero Trust Maturity Model — https://www.cisa.gov/zero-trust-maturity-model — gratuito
- [Video] IBM Technology — CIA Triad explained — https://youtube.com/@IBMTechnology — aprox. 8 min
- [Video] NetworkChuck — Zero Trust explained — https://youtube.com/@NetworkChuck — aprox. 12 min
- [TryHackMe] Pre-Security Path — https://tryhackme.com/path/outline/presecurity — módulos 2, 6 y 7